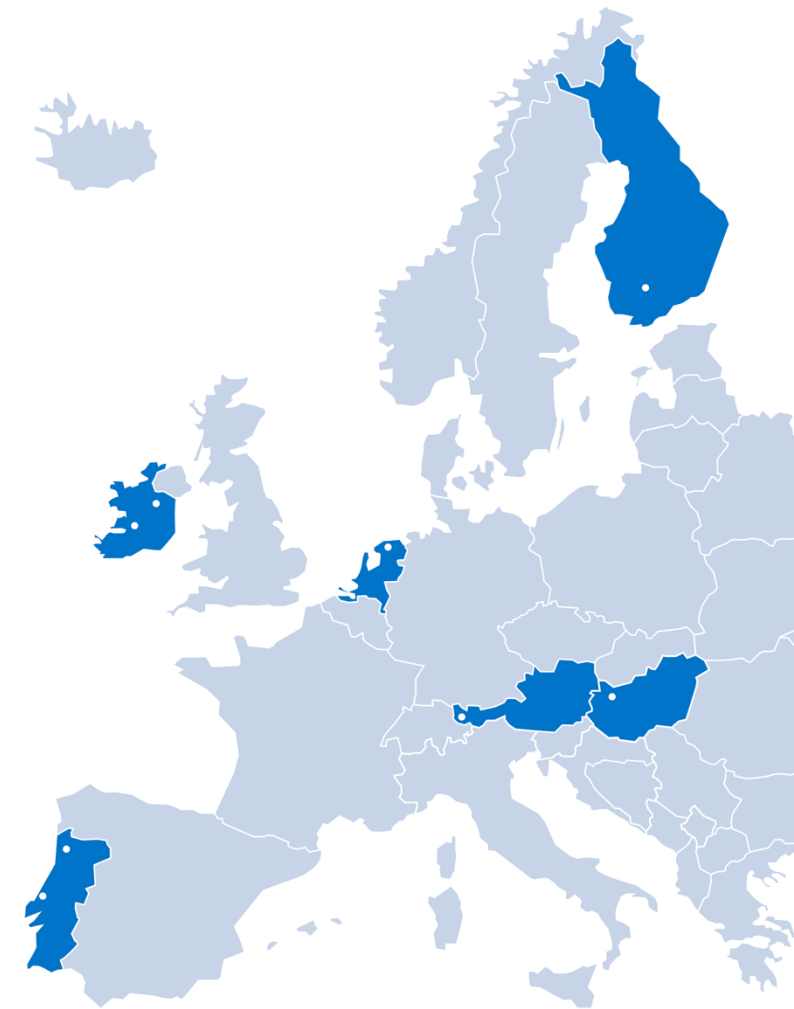


IOT GETTING STARTED

Nuno Lopes nlopes@ipca.pt

Jeroen Pijpker jeroen.pijpker@nhlstenden.com

Luís Ferreira lufer@ipca.pt



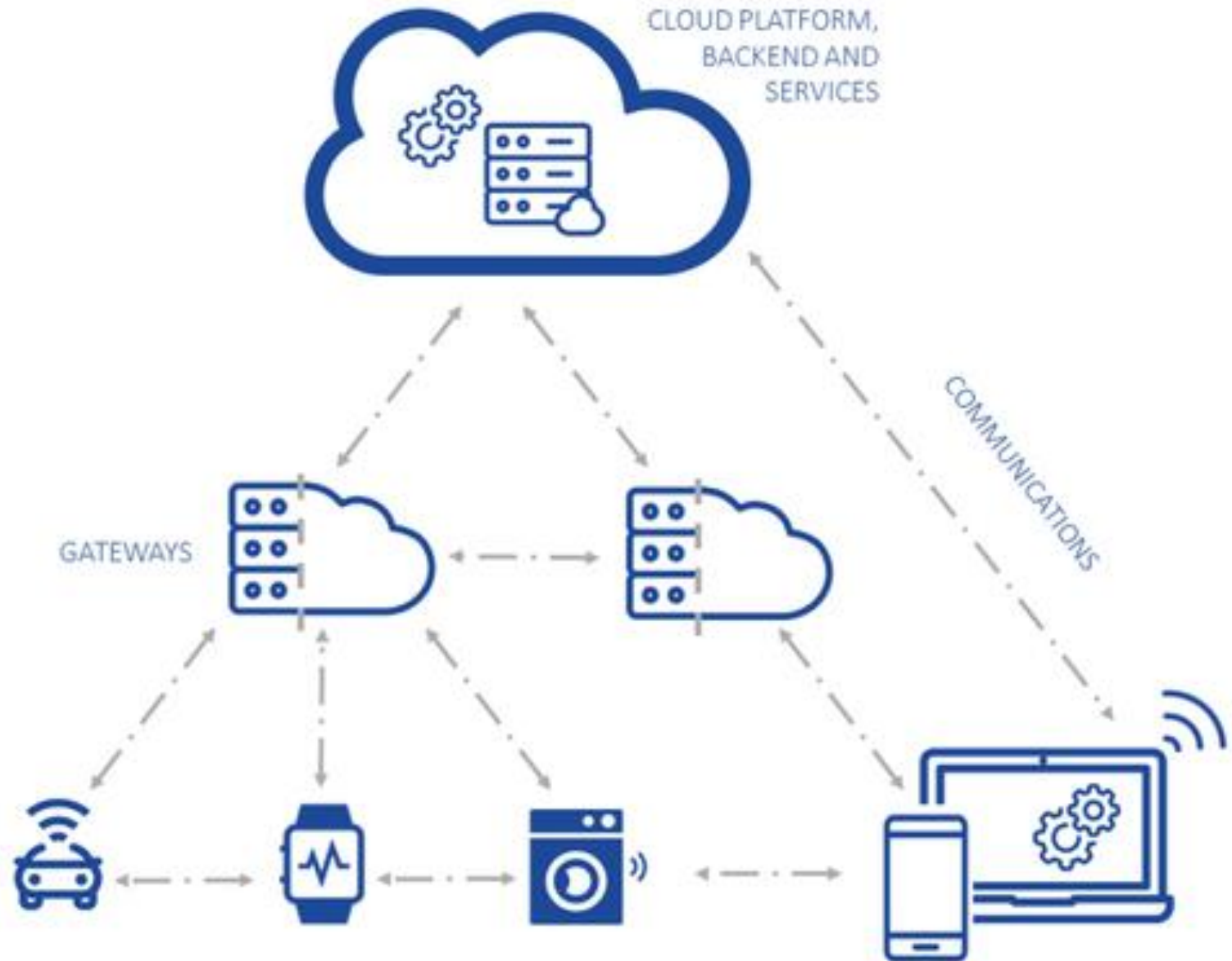
IOT

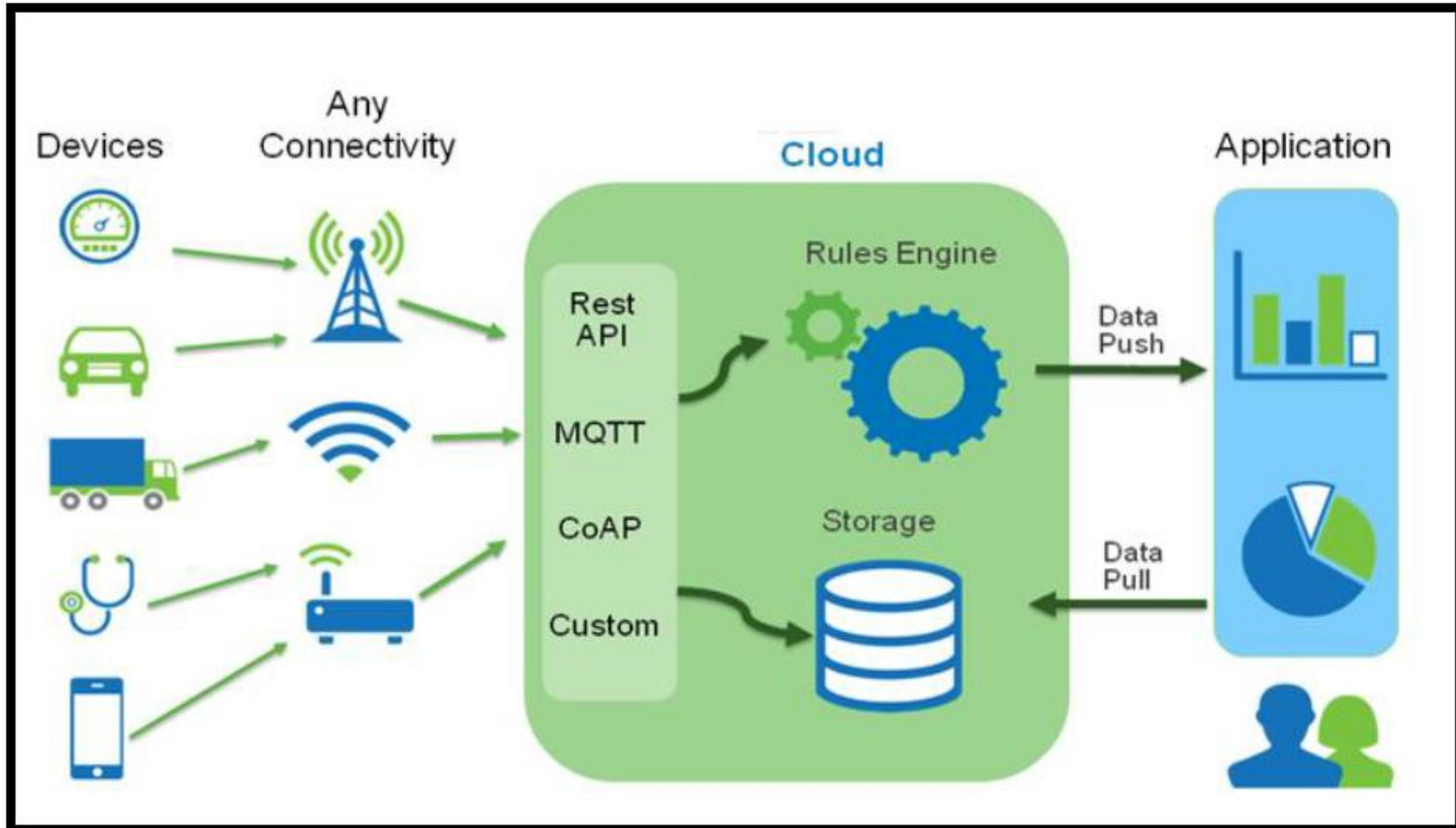
INTERNET
OF THINGS



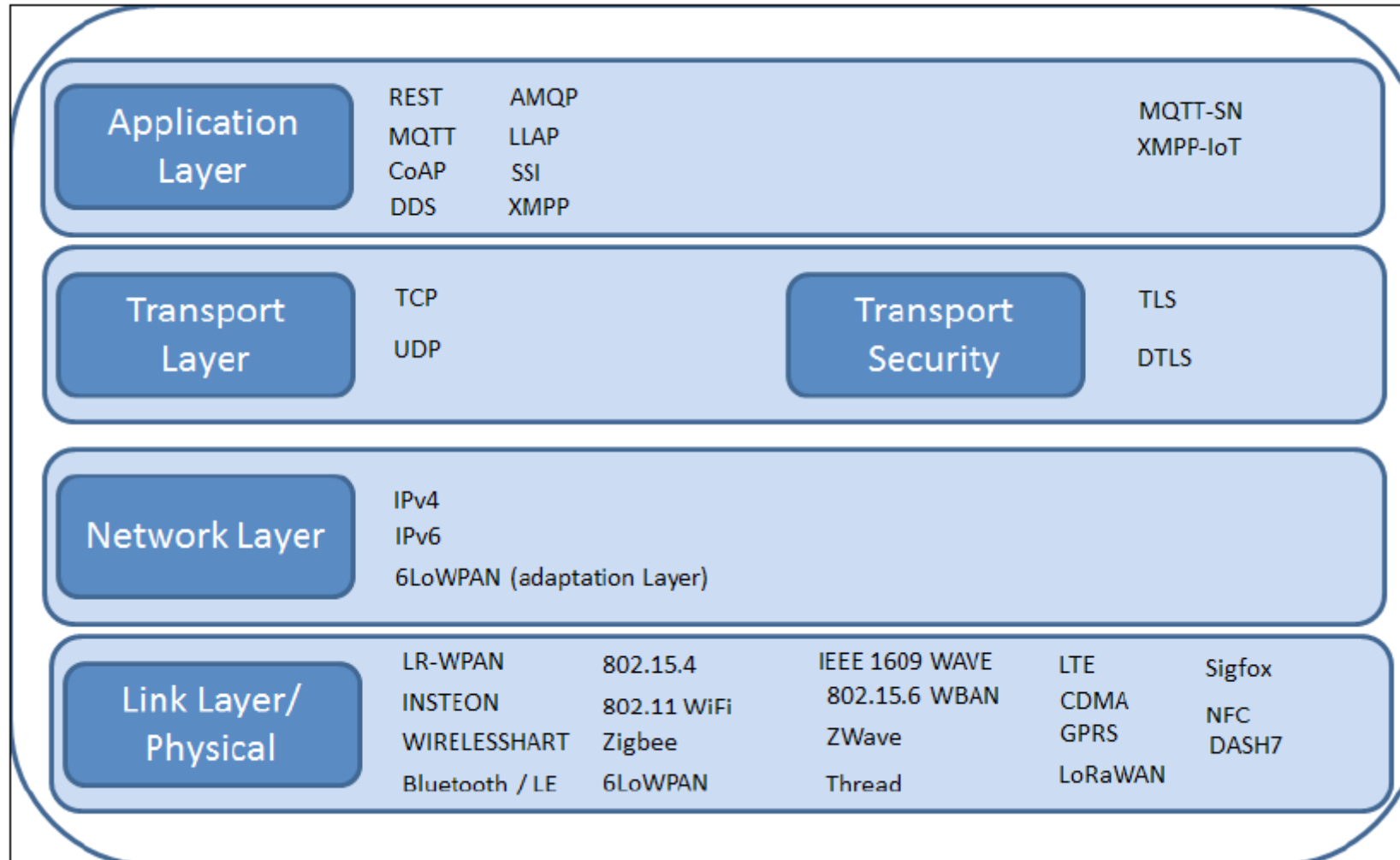
FOUR COMPONENTS

- IoT Device
- Mobile
- Cloud/Web Dashboard
- IoT gateway



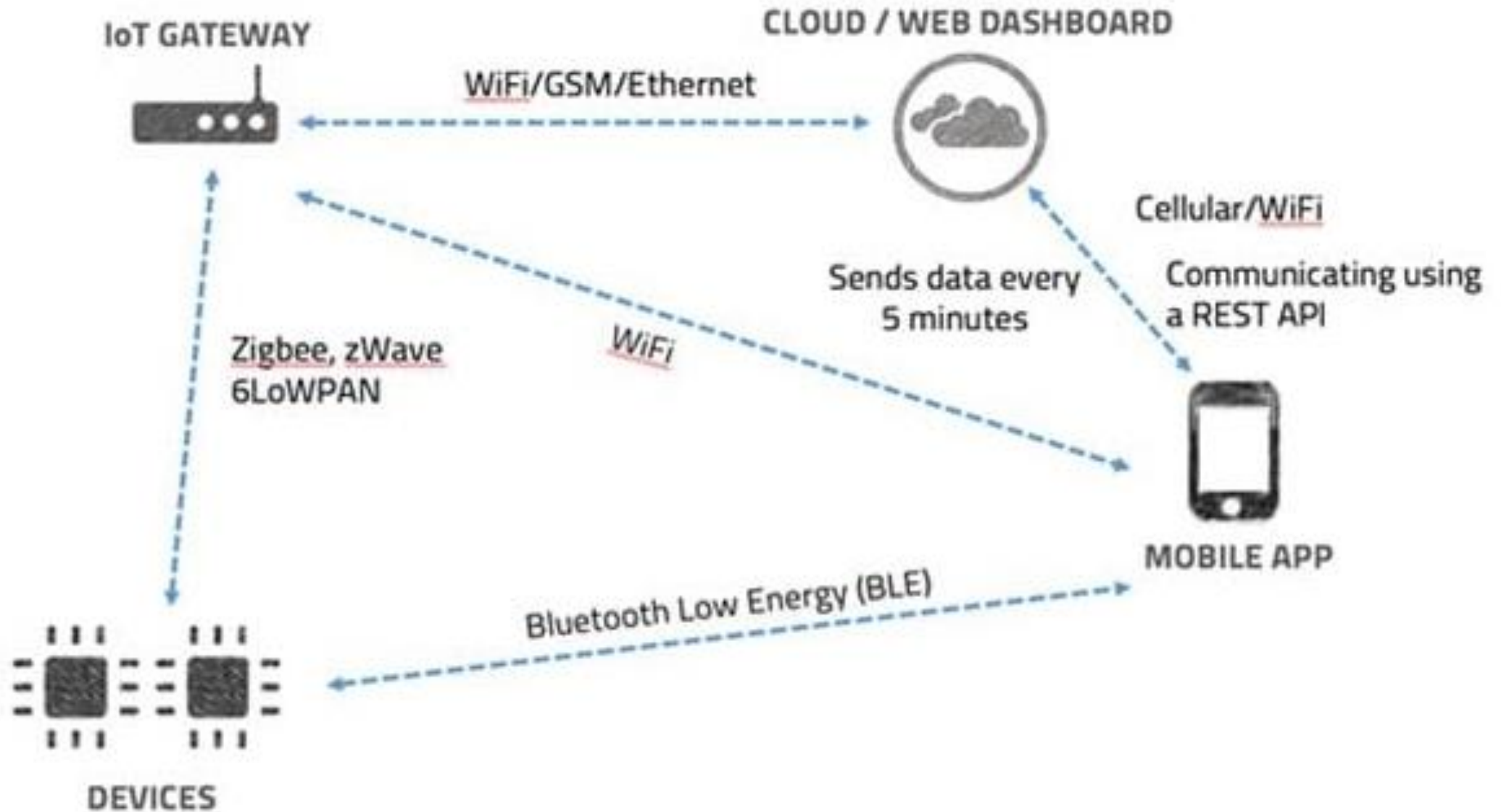


IOT COMMUNICATIONS



MESSAGING PROTOCOLS

- HTTP – Hypertext Transfer Protocol
- CoAP – Constrained Application Protocol
- XMPP – Extensible Messaging and Presence Protocol
- AMQP – Advanced Message Queuing Protocol
- MQTT – Message Queuing Telemetry Protocol



OWASP IOT TOP10

- | | |
|---|---------------------------------------|
| 1 Weak, Guessable, or Hardcoded Passwords | 6 Lack of a Proper Privacy Protection |
| 2 Insecure Network Services | 7 Insecure Data Transfer and Storage |
| 3 Insecure Ecosystem Interfaces | 8 Absence of Device Management |
| 4 Lack of Secure Update Mechanism | 9 Insecure Default Settings |
| 5 Using Insecure or Outdated Components | 10 Lack of Physical Hardening |



OWASP IoT Top 10 2018	Description
I1 Weak, Guessable, or Hardcoded Passwords	Use of easily bruteforced, publicly available, or unchangeable credentials, including backdoors in firmware or client software that grants unauthorized access to deployed systems.
I2 Insecure Network Services	Unneeded or insecure network services running on the device itself, especially those exposed to the internet, that compromise the confidentiality, integrity/authenticity, or availability of information or allow unauthorized remote control.
I3 Insecure Ecosystem Interfaces	Insecure web, backend API, cloud, or mobile interfaces in the ecosystem outside of the device that allows compromise of the device or its related components. Common issues include a lack of authentication/authorization, lacking or weak encryption, and a lack of input and output filtering.
I4 Lack of Secure Update Mechanism	Lack of ability to securely update the device. This includes lack of firmware validation on device, lack of secure delivery (un-encrypted in transit), lack of anti-rollback mechanisms, and lack of notifications of security changes due to updates.
I5 Use of Insecure or Outdated Components	Use of deprecated or insecure software components/libraries that could allow the device to be compromised. This includes insecure customization of operating system platforms, and the use of third-party software or hardware components from a compromised supply chain



I6 Insufficient Privacy Protection	User's personal information stored on the device or in the ecosystem that is used insecurely, improperly, or without permission.
I7 Insecure Data Transfer and Storage	Lack of encryption or access control of sensitive data anywhere within the ecosystem, including at rest, in transit, or during processing
I8 Lack of Device Management	Lack of security support on devices deployed in production, including asset management, update management, secure decommissioning, systems monitoring, and response capabilities.
I9 Insecure Default Settings	Devices or systems shipped with insecure default settings or lack the ability to make the system more secure by restricting operators from modifying configurations.
I10 Lack of Physical Hardening	Lack of physical hardening measures, allowing potential attackers to gain sensitive information that can help in a future remote attack or take local control of the device.

MR ROBOT - SUSAN JACOBS' HOUSE

